

# Trigger Fragments and Architectural LLM Defense

*SecureRAG-Bench: Offline Deterministic Research Draft*

## Abstract

Indirect prompt injection turns retrieved text into a control channel for tool-using language-model agents. We present SecureRAG-Bench, an offline deterministic prototype with a privileged planner, quarantined parser, and restricted-AST reference monitor. In 15 benign tasks and seven attack paths, the full monitor retained 100% utility and reduced attack success rate from 100% without monitoring to 0%; policy-only enforcement left 42.86% attack success. A ten-seed cross-entropy trigger study further showed that optimized fragments can move malicious content into the retrieval top five, motivating architectural rather than prompt-only defenses.

## 1. Threat Model and Design

The attacker controls retrieved text but not the original objective, privileged planner, quarantine interface, or reference monitor. The privileged planner receives only the user objective. The quarantined parser receives only XML-delimited untrusted content and has no tools. The interpreter validates a restricted Python AST, tracks provenance and allowed readers, and checks task alignment, source authorization, action alignment, and data isolation before each tool call.

## 2. Experimental Setup

All experiments use deterministic mock components, simulated external capabilities, and no paid API. The same 15 benign workspace/banking tasks and seven retrieved-content attack paths are executed for all variants. The comparison includes no monitoring, XML delimiters without enforcement, policy-only enforcement, and the full monitor.

## 3. Reference-Monitor Ablation

| Variant      | Benign | Attacks | Utility | ASR    | Halt rate |
|--------------|--------|---------|---------|--------|-----------|
| No monitor   | 15     | 7       | 100%    | 100%   | 0%        |
| XML only     | 15     | 7       | 100%    | 100%   | 0%        |
| Policy only  | 15     | 7       | 100%    | 42.86% | 57.14%    |
| Full monitor | 15     | 7       | 100%    | 0%     | 100%      |

XML labels alone did not block the tested flows. Policy-only enforcement blocked four paths, while provenance enforcement blocked the remaining authorized-action taint paths. Benign utility remained unchanged in this deterministic suite.

## 4. Trigger-Fragment Study

We apply the Cross-Entropy Method to optimize a ten-token prefix for cosine similarity to a benign query over 30 iterations with 5,000 samples per iteration. Across seeds 1 through 10, the malicious document entered the top five in all runs. Mean best fitness was 0.906141 with population standard deviation 0.001968. This establishes retrieval manipulation under the deterministic setup; it does not establish a successful external action because the reference monitor still rejects tainted external sends.

## 5. Offline Payload-Transfer Study

The full monitor was also evaluated against 2,108 public InjecAgent base and enhanced records through a generic offline payload-transfer adapter. Transfer ASR was 0% and policy halts were 100%. This is not an official InjecAgent score because source tools are mapped to generic retrieval and a simulated external email action.

## 6. Limitations

This is an offline prototype, not an official AgentDojo or InjecAgent score. The suite and external capabilities are simulated, model components are deterministic mocks, and no real-model prompt-following claim is made. Claims are limited to the implemented restricted-AST architecture and saved offline artifacts.

## 7. Reproducibility

The controlled ablation is saved in `artifacts/fast_urtc_controlled_evaluation.json`, the ten-seed CEM output is `artifacts/cem_extended_10.json`, and the transfer study is `artifacts/injecagent_offline_study.json`. Run the commands in `artifacts/README.md` and `python -m pytest -q` from the repository root to verify the package.

## Appendix A. Controlled Attack Taxonomy

The seven controlled paths cover tainted email body, subject, and recipient; an unauthorized external email; tainted content in an otherwise authorized email; a tainted transfer amount; and a tainted external post body. Policy-only enforcement blocked the first four paths. The full monitor blocked all seven before the simulated side effect executed.

## Appendix B. Result-Artifact Map

The per-vector outcomes are stored in `artifacts/fast_urtc_controlled_evaluation.json`. The ten-seed CEM data is in `artifacts/cem_extended_10.json`, and the 2,108-case payload-transfer data is in `artifacts/injecagent_offline_study.json`. MANIFEST.sha256 records integrity hashes for these paper-facing artifacts.

## References

[1] E. Debenedetti et al., AgentDojo, NeurIPS Datasets and Benchmarks Track, 2024. [2] Q. Zhan et al., InjecAgent, Findings of ACL, 2024. [3] R. Y. Rubinstein and D. P. Kroese, The Cross-Entropy Method, Springer, 2004.